26. 部署运维与可观测性（P0）

第 15 章是部署检查清单；本章补齐“上线后”工程底座：挂了谁知道、慢了查哪里、数据丢了怎么恢复。

规模	部署形态	关键组件	资源建议
试点/MVP	单机 Docker Compose	Dify+Qdrant+PG+MinIO+网关	8C16G 起；向量盘≥100G
多部门	Docker Swarm / K8s	无状态多副本；PG 主从	16C32G×2+；独立 GPU
集团/高并发	K8s + HPA	网关限流、向量集群	按 QPS 弹性；异地

- RTO ≤ 30 分钟、RPO ≤ 5 分钟；网关/应用/向量库均多副本，无单点。
- 可观测性三支柱：Metrics(Prometheus+Grafana)、Logs(Loki/ELK)、Traces(OpenTelemetry)，统一关联 tenant/dept/user。
- 灰度与回滚：提示词/知识库/工作流版本化，新模型先金丝雀 5% 再全量；回滚优先于修复。
- 告警分级 P1/P2/P3 对接 IM 值班群：错误率>1%、召回 P95>3s、备份失败等。



图 26.3 可观测性数据流：采集→存储→看板/告警

27. AI 行为安全（P0）

第 6 章覆盖“数据保密”，但企业更常遇到 AI 生成内容本身的风险。本章建立输入—知识—输出三层防护，与第 18 章权限过滤互补。

- 输入侧：提示注入/越狱检测、敏感指令拦截、输入清洗（截断/防路径遍历）。
- 知识侧（防投毒）：入库来源可信度校验、敏感文档审核、更新留痕可溯源回滚。
- 输出侧：内容安全过滤（违规/歧视/泄密）、幻觉缓解（强制引用+低置信拒答）、越权二次防线（输出层再校验 scope）。
- 人工兜底：高风险操作必人工确认；AI 输出不作最终决策唯一依据。

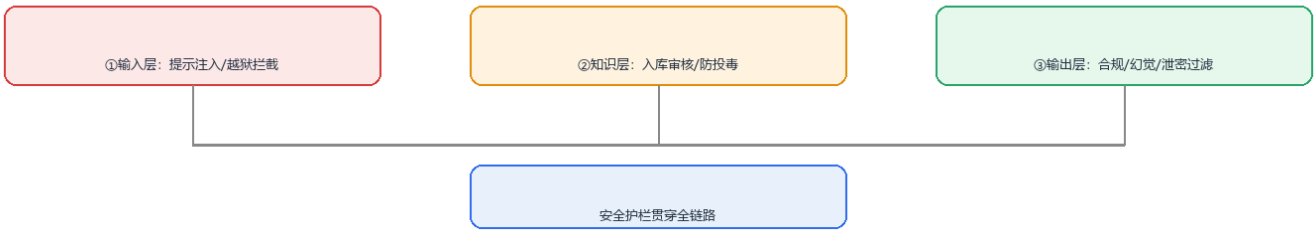


图 27 输入—知识—输出三层防护，安全护栏贯穿全链路

28. 测试与评测体系（P0）

层	对象	方法	门禁
单元	工具/函数/适配器	断言输入输出	覆盖率≥70%
集成	工作流/多Agent	端到端真实任务	关键路径全通
评测	问答/生成质量	golden set + LLM-as-judge	不劣于基线

- RAG 评测集：每部门 问题+标准答案+标准引用（≥50 条），指标=召回准确率/答案忠实度/引用完整度。
- LLM-as-judge 评分卡：相关性/合规性/引用完整/无害性 0–5 分；高风险部门人工抽检。
- 上线验收阈值示例：准确率≥85%、可引用率≥90%、越权拦截率 100%。



评测是自动演化(ch20)的效果度量尺

图 28 评测闭环：评测是自动演化（第 20 章）的效果度量尺

29. 审计与合规留存（P1）

字段	含义	示例
who	操作人+角色	张三 / 部门管理员
what	动作+对象	查询知识 / 导出文档
scope	可见范围上下文	dept=研发部
when	时间戳	ISO8601+时区
result	成功/拒绝+原因	拒绝：越权

- 留存：操作日志≥180 天、安全事件≥1 年；审计库独立、只读、加密。
- 合规映射：等保 2.0 三级、ISO 27001、数据安全法、个人信息保护。
- 数据主体权利：员工可导出/更正/删除本人数据，删除级联清理向量与索引。

30. 运营推广与价值度量（P1）

工具再好没人用等于失败。本章把“建好”推进到“用好”，并让管理层看到价值。

- 推广三阶段：试点（1–2 高意愿部门样板）→ 放大（沉淀模板中心复制）→ 常态化（纳入考核/日报）。
- 培训：管理员（权限/知识库/编排）、种子用户（业务转智能体）、全员（怎么问、看什么范围）。
- 活跃度：DAU/WAU、采纳率、任务完成率、部门渗透率看板。
- 价值 ROI：节省工时、响应提速、质量提升，结合第 25 章成本算净收益。
- 反馈闭环接入第 20 章自动演化：点赞/纠错 → 知识缺口 → 自生长 → 评测验证 → 灰度发布。

31. 统一身份与集成架构（P1）

集成对象	方式	场景
企微/钉钉/飞书	机器人+侧边栏+推送	对话入口、通知、审批
OA/审批	OpenAPI/Webhook	流程联动、单据生成
ERP/CRM	连接器+数据回流	客户/订单查询、报表

- SSO 深化：OIDC/SAML/LDAP，目录同步；入/转/离自动开通回收，权限随岗位变更。
- 事件总线/Webhook：知识入库、审批通过等事件异步触发工作流；集成调用同样走第 18 章过滤点。

32. 多租户与集团化隔离（P2）

当前蓝图以“单公司 + 部门”为主。若客户是集团、多子公司或多品牌，需在部门之上增加“租户（tenant）”一层隔离。

- 层级：租户(tenant) > 部门(dept) > 个人；权限元数据增 tenant_id。
- 隔离粒度：默认逻辑隔离（同库不同 tenant_id）；高敏客户可选物理隔离（独立库/部署）。
- 集团级：统一策略下发、跨租户白名单协作、按租户配额/计费分摊（衔接第 25 章）。

33. 法律与责任界定（P2）

事项	建议约定
AI 生成内容归属	职务作品归企业；员工对最终采用负责
责任边界	AI 输出不替代专业判断；关键决策人机共签
免责声明	对外内容标注“AI 辅助生成，请核实”

- 使用守则：禁止把机密/个人信息输入公网模型；内部平台按 scope 使用。
- 数据合规：遵守个人信息保护法；境外模型需评估数据出境合规。

34. 性能与成本优化（P2）

规模上来后，延迟与成本会同时成为瓶颈。本章给出可落地优化手段，并与第 25 章计量计费联动。

- 缓存：召回结果缓存、热点知识/模型响应缓存（Redis）。
- 并发与限流：网关节流、请求队列削峰、模型并发受配额约束。
- 按难度路由：简单任务走小模型、复杂才用大模型，混合推理显著降本。
- 向量库优化：HNSW 索引、分片、冷热分离；效果在成本看板（第 25 章）可观测。